Data Processing Agreement

Effective November 2, 2026. This Data Processing Agreement supersedes and replaces all prior versions.

This Data Processing Agreement (the “Agreement”) between Provider (sometimes referred to as “Provider,” “we,” “us,” or “our”), and the Client found on the applicable Order (sometimes referred to as “you,” or “your,”) is part of the Agreement under the Master Services Agreement. It applies to the extent Provider processes the regulated information described in each section below. If this Data Processing Agreement conflicts with another Contract Document as to that information, this Data Processing Agreement controls.

The parties agree as follows:

---

1. Health Insurance Portability and Accountability Act (“HIPAA”)

Protected Health Information is governed by the Business Associate Agreement, which applies automatically under Section 13.2 of the Master Services Agreement. This Data Processing Agreement does not apply to Protected Health Information. For Orders signed before November 2, 2026, Section 1 of the version of this Data Processing Agreement in effect when the Order was signed continues to apply unless Client elects in writing to adopt the Business Associate Agreement.

---

2. Gramm-Leach-Bliley Act (“GLBA”) Data Processing

This section documents the safeguard standards imposed to protect Client financial information subject to the Gramm-Leach Bliley Act

("GLBA"). To the extent Provider's services constitute processing of financial information governed by GLBA, these provisions shall apply.

a. Definitions

All capitalized terms in this Addendum which are not otherwise defined in this Addendum or in the MSA have the meaning set forth in Title V of the Gramm-Leach-Bliley Act (P. L. 106-102; 15 USC §6801 et seq.) and the regulations issued pursuant thereto by the Financial Institution's Functional Regulator.

b. Receipt of Information

To perform its duties under the Agreement, Provider is authorized and permitted to receive, hold and, to the extent necessary, review Nonpublic Personal Information of Client in order to provide services for Client at Client's direction as provided under the MSA. Provider may further use and disclose Nonpublic Personal Information for the proper management and administration of the business of Provider.

c. Obligations of Service Provider

Provider will take reasonable steps to:

- Implement and maintain a written comprehensive information security program containing administrative, technical and physical safeguards for the security and protection of Nonpublic Personal Information and further containing each of the elements set forth in § 314.4 of the Gramm Leach Bliley Standards for Safeguarding Client Information (16 C.F.R. § 314) and the Red Flag Rules issued by the Federal Trade Commission;
- Ensure the security and confidentiality of Nonpublic Personal Information received from Client;
- Protect against any anticipated threats or hazards to the security or integrity of Nonpublic Personal Information;
- Protect against unauthorized access to or use of such information that could result in harm or inconvenience to Client;

- Ensure the proper disposal of Nonpublic Personal Information, as set forth in the MSA or in Service Attachments signed under the MSA, and
- Notify Client of any loss or breach of the security or Confidentiality of Client's Nonpublic Personal Information.

d. Permitted Uses and Disclosures

Provider may disclose the information received by it under the Agreement only if the disclosure is required by law.

e. Permissible Requests

Client shall not request Provider to use or disclose Nonpublic Personal Information in any manner that would not be permissible Title V of the Gramm-Leach-Bliley Act (P. L. 106-102; 15 USC §6801 et seq.) and the regulations issued pursuant thereto if done by Client.

---

3. Department of Defense Standards for Controlled Unclassified Information ("CUI")

This section documents the safeguards imposed to protect CUI subject to the DoD and CMMC's standards. To the extent Provider's services involve CUI subject to DoD or CMMC standards or regulations, these provisions shall apply.

a. System Environment. Provider will prepare a detailed description of system boundaries, system interconnectedness, and key devices.

b. Requirements. Provider will thoroughly describe how the CMMC requirements have been implemented for each of the following:

- Access Control
- Awareness and Training
- Audit and Accountability
- Configuration Management

- Identification and Authentication
- Incident Response
- Maintenance
- Media Protection
- Personnel Security
- Physical Protection
- Risk Assessment
- Security Assessment
- System and Communication Protection
- System and Information Integrity

---

4. California Consumer Privacy Act

This section documents the safeguard standards imposed to protect Client information subject to the California Consumer and Privacy Act ("CCPA"). To the extent Provider's services constitute processing of personal information governed by CCPA, these provisions shall apply.

a. Definitions

- "CCPA" means the California Consumer Privacy Act of 2018, Cal. Civ. Code §1798.100 et. seq., and its implementing regulations.
- "Client Personal Information" means any Client Data maintained by Client and processed by Provider solely on Client's behalf, that identifies, relates to, describes, is capable of being associated with, or could reasonably be linked, directly or indirectly, with a particular consumer or household, to the extent that such information is protected as "personal information" (or an analogous variation of such term) under applicable U.S. Data Protection Laws.
- "U.S. Data Protection Laws" means all laws and regulations of the United States of America, including the CCPA, applicable to the processing of personal information (or an analogous variation of such term).

- “Service Provider” has the meaning set forth in Section 1798.140(v) of the CCPA.

b. Roles. The parties acknowledge and agree that with regard to the processing of Client Personal Information performed solely on behalf of Client, Provider is a Service Provider and receives Client Personal Information pursuant to the business purpose of providing the Services to Client in accordance with the Agreement.

c. No Sale of Client Personal Information to Provider. Client and Provider hereby acknowledge and agree that in no event shall the transfer of Client Personal Information from Client to Provider pursuant to the Agreement constitute a sale of information to Provider, and that nothing in the Agreement shall be construed as providing for the sale of Client Personal Information to Provider.

d. Limitations on Use and Disclosure. Provider is prohibited from using or disclosing Client Personal Information for any purpose other than the specific purpose of performing the Services specified in the Agreement, the permitted business purposes set under applicable law, and as required under applicable law. Provider hereby certifies that it understands the foregoing restriction and will comply with it in accordance with the requirements of applicable U.S. Data Protection Laws.

e. Data Subject Access Requests. Provider will reasonably assist Client with any data subject access, erasure or opt-out requests and objections. If Provider receives any request from data subjects, authorities, or others relating to its data processing, Provider will without undue delay inform Client and reasonably assist Client with developing a response (but Provider will not itself respond other than to confirm receipt of the request, to inform the data subject, authority or other third party that their request has been forwarded to Client, and/or to refer them to Client, except per reasonable instructions from Client). Provider will also reasonably assist Client with the resolution of any request or inquiries that Client receives from data protection authorities relating to Provider, unless Provider elects to object such requests directly with such authorities.

5. Colorado Privacy Act

This section documents the safeguard standards imposed to protect Client information subject to the Colorado Privacy Act (6-1-1301) (“CPA”). To the extent Provider’s services constitute processing of personal information governed by CPA, these provisions shall apply.

Provider shall adhere to the instructions of the controller and assist the controller to meet its obligations under the CPA.

Taking into account the nature of processing and the information available to Provider, Provider shall assist the controller by:

- taking appropriate technical and organizational measures, insofar as this is possible, for the fulfillment of the controller’s obligation to respond to consumer requests to exercise their rights pursuant to section 6-1-1306;
- helping to meet the controller’s obligations in relation to the security of processing the personal data and in relation to the notification of a breach of the security of the system pursuant to section 6-1-716; and
- providing information to the controller necessary to enable the controller to conduct and document any data protection assessments required by section 6-1-1309.

Notwithstanding the instructions of the controller, Provider shall:

- ensure that each person processing the personal data is subject to a duty of confidentiality with respect to the data; and
- engage a subcontractor only after providing the controller with an opportunity to object and pursuant to a written contract that requires the subcontractor to meet the obligations of the processor with respect to the personal data.

Taking into account the context of processing, Provider shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk and establish a clear allocation of the

responsibilities between Provider and the controller to implement the measures.

Processing by Provider must be governed by a contract between the controller and Provider that is binding on both parties and that sets out:

- the processing instructions to which the processor is bound, including the nature and purpose of the processing;
- the type of personal data subject to the processing, and the duration of the processing; and
- the following requirements:
  - at the choice of the controller, Provider shall delete or return all personal data to the controller as requested at the end of the provision of services, unless retention of the personal data is required by law;
  - Provider shall make available to the controller all information necessary to demonstrate compliance with the obligations; and
  - Provider shall allow for, and contribute to, reasonable audits and inspections by the controller or the controller's designated auditor. Alternatively, Provider may, with the controller's consent, arrange for a qualified and independent auditor to conduct, at least annually and at Provider's expense, an audit of the Provider's policies and technical and organizational measures in support of its obligations under the CPA using an appropriate and accepted control standard or framework and audit procedure for the audits as applicable. Provider shall furnish a report of the audit to the controller upon request.

---

6. Connecticut Privacy Act

This section documents the safeguard standards imposed to protect Client information subject to the Connecticut SB 12-2 ("Conn Act"). To the extent Provider's services constitute processing of personal information governed by Conn Act, these provisions shall apply.

Provider shall adhere to the instructions of a controller and shall assist the controller in meeting the controller's obligations under the Conn Act. Such assistance shall include:

- taking into account the nature of processing and the information available to Provider, providing appropriate technical and organizational measures to fulfill the controller's obligation to respond to consumer rights requests;
- taking into account the nature of processing and the information available to Provider, by assisting the controller in meeting the controller's obligations in relation to the security of processing the personal data and in relation to the notification of a breach of security of Provider's systems, in order to meet the controller's obligations; and
- providing necessary information to enable the controller to conduct and document data protection assessments.

Provider shall have a written contract with the controller that will govern the Provider's data-processing procedures with respect to processing performed on behalf of the controller. The contract shall be binding and clearly set forth instructions for processing data, the nature and purpose of processing, the type of data subject to processing, the duration of processing and the rights and obligations of both parties. The contract shall also require that Provider:

- Ensure that each person processing personal data is subject to a duty of confidentiality with respect to the data;
- At the controller's direction, delete or return all personal data to the controller as requested at the end of the provision of services, unless retention of the personal data is required by law;
- Upon the reasonable request of the controller, make available to the controller all information in its possession necessary to demonstrate Provider's compliance with the obligations
- after providing the controller an opportunity to object, engage any subcontractor pursuant to a written contract that requires the

subcontractor to meet the obligations of Provider with respect to the personal data; and

- allow, and cooperate with, reasonable assessments by the controller or the controller's designated assessor, or the processor may arrange for a qualified and independent assessor to conduct an assessment of Provider's policies and technical and organizational measures in support of the obligations of the Conn Act using an appropriate and accepted control standard or framework and assessment procedure for such assessments.

Provider shall provide a report of such assessment to the controller upon request.

For purposes of the Conn Act, the following definitions apply:

- "Consumer" means an individual who is a resident of this state. "Consumer" does not include an individual acting in a commercial or employment context or as an employee, owner, director, officer or contractor of a company, partnership, sole proprietorship, nonprofit or government agency whose communications or transactions with the controller occur solely within the context of that individual's role with the company, partnership, sole proprietorship, nonprofit or government agency.
- "Controller" means an individual who, or legal entity that, alone or jointly with others determines the purpose and means of processing personal data.
- "Personal data" means any information that is linked or reasonably linkable to an identified or identifiable individual. "Personal data" does not include de-identified data or publicly available information.
- "Process" or "processing" means any operation or set of operations performed, whether by manual or automated means, on personal data or on sets of personal data, such as the collection, use, storage, disclosure, analysis, deletion or modification of personal data.
- "Processor" means an individual who, or legal entity that, processes personal data on behalf of a controller

7. New York SHIELD

Provider maintains a comprehensive, written information security program that contains administrative, technical, and physical safeguards that are appropriate to (a) the size, scope and type of Provider's business; (b) the amount of resources available to Provider; (c) the type of information that Provider will store; and (d) the need for security and confidentiality of such information. Provider may update its security program from time to time, provided that no update materially reduces the protection it provides.

Provider's security program is designed to:

- Protect the confidentiality, integrity, and availability of Customer Data or Professional Services Data in Provider's possession or control or to which Provider has access;
- Protect against any anticipated threats or hazards to the confidentiality, integrity, and availability of Customer Data or Professional Services Data;
- Protect against unauthorized or unlawful access, use, disclosure, alteration, or destruction of Customer Data or Professional Services Data;
- Protect against accidental loss or destruction of, or damage to, Customer Data or Professional Services Data; and
- Safeguard information as set forth in any local, state or federal regulations by which Provider may be regulated.

Without limiting the generality of the foregoing, Provider's security program includes:

1. Security Awareness and Training. A mandatory security awareness and training program for all members of Provider's workforce (including management), which includes:

- Training on how to implement and comply with its Information Security Program;

- Promoting a culture of security awareness through periodic communications from senior management with employees.

2. Access Controls. Policies, procedures, and logical controls:

- To limit access to its information systems and the facility or facilities in which they are housed to properly authorized persons;
- To prevent those workforce members and others who should not have access from obtaining access; and
- To remove access in a timely basis in the event of a change in job responsibilities or job status.

3. Physical and Environmental Security. Controls that provide reasonable assurance that access to physical servers at the production data center or the facility housing Provider's SFTP Server, if applicable, is limited to properly authorized individuals and that environmental controls are established to detect, prevent and control destruction due to environmental extremes. These controls include:

- Logging and monitoring of unauthorized access attempts to the data center by the data center security personnel;
- Camera surveillance systems at critical internal and external entry points to the data center;
- Systems that monitor and control the air temperature and humidity at appropriate levels for the computing equipment; and
- Uninterruptible Power Supply (UPS) modules and backup generators that provide back-up power in the event of an electrical failure.

4. Security Incident Procedures. A security incident response plan that includes procedures to be followed in the event of any Security Breach. Such procedures include:

- Roles and responsibilities: formation of an internal incident response team with a response leader;
- Investigation: assessing the risk the incident poses and determining who may be affected;

- Communication: internal reporting as well as a notification process in the event of unauthorized disclosure of Customer Data or Professional Services Data;
- Recordkeeping: keeping a record of what was done and by whom to help in later analysis and possible legal action; and
- Audit: conducting and documenting root cause analysis and remediation plan.

5. Contingency Planning. Policies and procedures for responding to an emergency or other occurrence (for example, fire, vandalism, system failure, pandemic flu, and natural disaster) that could damage Customer Data or production systems that contain Customer Data. Such procedures include:

- Data Backups: A policy for performing periodic backups of production file systems and databases or Professional Services Data on Provider's SFTP Server, as applicable, according to a defined schedule;
- Disaster Recovery: A formal disaster recovery plan for the production data center, including:
  - Requirements for the disaster plan to be tested on a regular basis, currently twice a year; and
  - A documented executive summary of the Disaster Recovery testing, at least annually, which is available upon request to customers.
- Business Continuity Plan: A formal process to address the framework by which an unplanned event might be managed in order to minimize the loss of vital resources.

6. Audit Controls. Hardware, software, and/or procedural mechanisms that record and examine activity in information systems that contain or use electronic information.

7. Data Integrity. Policies and procedures to ensure the confidentiality, integrity, and availability of Customer Data or Professional Services Data and protect it from disclosure, improper alteration, or destruction.

8. Storage and Transmission Security. Security measures to guard against unauthorized access to Customer Data or Professional Services

Data that is being transmitted over a public electronic communications network or stored electronically. Such measures include requiring encryption of any Customer Data or Professional Services Data stored on desktops, laptops or other removable storage devices.

9. Secure Disposal. Policies and procedures regarding the secure disposal of tangible property containing Customer Data or Professional Services Data, taking into account available technology so that Customer Data or Professional Services Data cannot be practicably read or reconstructed.

10. Assigned Security Responsibility. Assigning responsibility for the development, implementation, and maintenance of its Information Security Program, including:

- Designating a security official with overall responsibility;
- Defining security roles and responsibilities for individuals with security responsibilities; and
- Designating a Security Council consisting of cross-functional management representatives to meet on a regular basis.

11. Testing. Regularly testing the key controls, systems and procedures of its information security program to validate that they are properly implemented and effective in addressing the threats and risks identified.

12. Monitoring. Network and systems monitoring, including error logs on servers, disks and security events for any potential problems. Such monitoring includes:

- Reviewing changes affecting systems handling authentication, authorization, and auditing;
- Reviewing privileged access to Provider production systems; and
- Engaging third parties to perform network vulnerability assessments and penetration testing on a regular basis.

13. Change and Configuration Management. Maintaining policies and procedures for managing changes Provider makes to production

systems, applications, and databases. Such policies and procedures include:

- A process for documenting, testing and approving the patching and maintenance of the Service;
- A security patching process that requires patching systems in a timely manner based on a risk analysis; and
- A process for Provider to utilize a third party to conduct web application-level security assessments. These assessments generally include testing, where applicable, for:
  - Cross-site request forgery
  - Services scanning
  - Improper input handling (e.g., cross-site scripting, SQL injection, XML injection, cross-site flashing)
  - XML and SOAP attacks
  - Weak session management
  - Data validation flaws and data model constraint inconsistencies
  - Insufficient authentication
  - Insufficient authorization

14. Program Adjustments. Provider monitors, evaluates, and adjusts, as appropriate, the security program in light of:

- Any relevant changes in technology and any internal or external threats to Provider or the Customer Data or Professional Services Data;
- Security and data privacy regulations applicable to Provider; and
- Provider’s own changing business arrangements, such as mergers and acquisitions, alliances and joint ventures, outsourcing arrangements, and changes to information systems.

15. Devices. All laptop and desktop computing devices utilized by Provider and any subcontractors when accessing Customer Data or Professional Services Data:

- will be equipped with hard disk drive encryption;

- will have up to date virus and malware detection and prevention software installed with virus definitions updated on a regular basis; and
- shall maintain virus and malware detection and prevention software so as to remain on a supported release. This shall include, but not be limited to, promptly implementing any applicable security-related enhancement or fix made available by supplier of such software.

Definitions

“Professional Services” means consulting or professional services provided to Customer under an agreement between the parties for the provision of consulting or professional services.

“Professional Services Data” means electronic data or information that is provided to Provider under a Professional Services engagement with Provider for the purpose of being input into the Provider Service, or Customer Data accessed within or extracted from the Customer’s tenant to perform the Professional Services.

“SFTP Server” means a Secure File Transfer Protocol server or its successor provided and controlled by Provider to transfer the Professional Services Data between Customer and Provider for implementation purposes.

---

8. Virginia Privacy Act

This section documents the safeguard standards imposed to protect Client information subject to the Code of Virginia Section 59.1-579 (“VPA”). To the extent Provider’s services constitute processing of personal information governed by VPA, these provisions shall apply:

a. This DPA sets forth instructions for the following:

- Provider may provide hosting services and will only process data that is deposited by Client into Provider’s systems;

- Provider will not use non-anonomyzed protected data for any of its own business purposes;
- Any processing will be for a reasonable amount of time given the Services to be performed; and
- Both Provider and Client have the right to adjust whether Client may deposit protected data into Provider's systems.

b. With respect to the protected data, Provider shall:

- Ensure that each person processing personal data is subject to a duty of confidentiality with respect to the data;
- At the Client's direction, delete or return all protected data to the Client as requested at the end of the provision of services, unless retention of the protected data is required by law;
- Upon the reasonable request of the Client, make available to the Client all information in its possession necessary to demonstrate the Provider's compliance with the obligations in this chapter;
- Allow, and cooperate with, reasonable assessments by the Client or the Client's designated assessor; alternatively, Provider may arrange for a qualified and independent assessor to conduct an assessment of the Provider's policies and technical and organizational measures in support of the obligations under this chapter using an appropriate and accepted control standard or framework and assessment procedure for such assessments. Provider shall provide a report of such assessment to the Client upon request; and
- Engage any subcontractor pursuant to a written contract that requires the subcontractor to meet the obligations of the Provider with respect to the protected data.

Version history

VERSION	EFFECTIVE	STATUS
		Current — supersedes and replaces all prior versions. Changes: Section 1 (HIPAA) replaced

Data Processing Agreement	November 2, 2026	by a reference to the new Business Associate Agreement; precedence statement added; security program updates may not materially reduce protection. Sections 2–8 otherwise unchanged.
Data Processing Agreement	July 1, 2026	Superseded November 2, 2026 — archived version · PDF. Entity name corrected to “The Boom Company” (no “Inc.”) on August 30, 2026 — typographical correction only; no change to terms.
Data Processing Agreement	December 1, 2023	Superseded July 1, 2026 (available on request)